#A Extract the ID token from the request and verify the signature.
#B Ensure the token is from a trusted issuer and that this API is the intended audience.
#C If the ID token has an azp claim, then ensure it's the for same client that is calling the API.
#D Check that the subject of the ID token matches the resource owner of the access token.
#E Store the verified ID token claims in the request attributes for further processing.

7.7 Summary

- Scoped tokens allow clients to be given access to some parts of your API but not others, allowing users to delegate limited access to third-party apps and services.
- The OAuth2 standard provides a framework for third-party clients to register with your API and negotiate access with user consent.
- All user-facing API clients should use the authorization code grant with PKCE to obtain access tokens, whether they are traditional web apps, SPAs, mobile apps, or desktop apps. The implicit grant should no longer be used.
- The standard token introspection endpoint can be used to validate an access token, or JWT-based access tokens can be used to reduce network roundtrips. Refresh tokens can be used to keep token lifetimes short without disrupting the user experience.
- The OpenID Connect standard builds on top of OAuth2 providing a comprehensive framework for offloading user authentication to a dedicated service. ID tokens